

---

# Rules of Engagement & Master Services Agreement

Master Services Agreement

---

Prepared By: [YOUR COMPANY NAME]

Date: [DATE]

Client: [CLIENT COMPANY NAME]

Classification: CONFIDENTIAL

# Rules of Engagement & Master Services Agreement

---

## CYBERSECURITY ASSESSMENT SERVICES AGREEMENT

---

This Agreement ("Agreement") is entered into as of [DATE] ("Effective Date") by and between:

Service Provider:

[YOUR COMPANY NAME] ("Consultant")

[Address]

[City, State ZIP]

Contact: [Name], [Phone], [Email]

Client:

[CLIENT COMPANY NAME] ("Client")

[Address]

[City, State ZIP]

Contact: [Name], [Title], [Phone], [Email]

---

## 1. SCOPE OF SERVICES

### 1.1 Engagement Type

The Consultant will perform the following security assessment services as detailed in the attached Statement of Work (Exhibit A):

- ☐ External Penetration Test
- ☐ Internal Penetration Test
- ☐ Web Application Assessment
- ☐ Wireless Security Assessment
- ☐ Cloud Security Audit
- ☐ Social Engineering Assessment
- ☐ Vulnerability Assessment
- ☐ Compliance Audit

## [ ] Continuous Monitoring Services

### 1.2 Authorized Testing Activities

The Client explicitly authorizes the Consultant to perform the following activities against in-scope systems:

- Network scanning and enumeration
- Vulnerability scanning and identification
- Controlled exploitation of discovered vulnerabilities
- Password testing (spraying, brute force against test accounts)
- Web application testing (injection, authentication bypass, etc.)
- Wireless network assessment (if included in scope)
- Social engineering (if included in scope)
- Privilege escalation and lateral movement
- Cloud configuration review and testing
- OSINT and reconnaissance gathering

### 1.3 Prohibited Activities

The following activities are explicitly NOT authorized:

- Denial of Service (DoS/DDoS) attacks
- Intentional destruction or modification of production data
- Testing of systems outside the defined scope
- Physical intrusion or facility access testing (unless specified)
- Actions that could cause service outages to production systems
- Exfiltration of actual customer/employee PII, PHI, or financial data
- Installation of persistent backdoors on production systems
- Any testing of third-party systems not owned by the Client

### 1.4 In-Scope Systems

| Asset | IP Range / URL | Environment | Notes |
|-------|----------------|-------------|-------|
|-------|----------------|-------------|-------|

### 1.5 Out-of-Scope Systems

| Asset | IP Range / URL | Reason |
|-------|----------------|--------|
|-------|----------------|--------|

## 2. TESTING SCHEDULE

### 2.1 Testing Window

- Start Date: [DATE]
- End Date: [DATE]
- Testing Hours: [e.g., 24/7 OR Business hours only: Mon-Fri 8AM-6PM EST]
- Blackout Dates: [Any dates testing must NOT occur]

## 2.2 Notification Requirements

- Testing will begin no earlier than the Start Date above
- Consultant will notify Client's designated contact at least 24 hours before beginning active exploitation
- Consultant will immediately notify Client if testing causes any unintended service disruption

## 3. EMERGENCY CONTACTS & ESCALATION

### 3.1 Client Emergency Contacts

If critical issues are discovered or unintended disruptions occur:

| Priority         | Name | Title | Phone | Email |
|------------------|------|-------|-------|-------|
| Primary          |      |       |       |       |
| Secondary        |      |       |       |       |
| IT/Security Team |      |       |       |       |

### 3.2 Consultant Emergency Contacts

| Priority        | Name | Phone | Email |
|-----------------|------|-------|-------|
| Lead Tester     |      |       |       |
| Project Manager |      |       |       |

### 3.3 Critical Finding Notification

If the Consultant discovers a critical or actively exploited vulnerability, the Consultant will:

1. Immediately cease testing on the affected system
2. Notify the Client's primary emergency contact within 1 hour
3. Provide preliminary details and recommended immediate mitigation
4. Document the finding in the final report

## 4. RULES OF ENGAGEMENT

### 4.1 Testing Approach

- [ ] Black Box — No prior knowledge of systems provided
- [ ] Gray Box — Limited information provided (credentials, documentation)
- [ ] White Box — Full access to source code, architecture, credentials

## 4.2 Credentials Provided (if Gray/White Box)

| System | Username | Access Level | Purpose |
|--------|----------|--------------|---------|
|--------|----------|--------------|---------|

## 4.3 Network Access

- [ ] Testing from external (internet) only
- [ ] VPN access provided for internal testing
- [ ] On-site physical access / drop box deployment
- [ ] Remote access via [method]

VPN/Access Details:

- Connection method: [VPN type, credentials, etc.]
- Source IP to whitelist: [Consultant's testing IP]

## 4.4 Evidence Handling

- Screenshots and logs will be captured as evidence of findings
- No actual sensitive data (PII, PHI, credentials) will be stored in reports — only proof of access
- All evidence stored encrypted during the engagement
- Evidence securely destroyed [30/60/90] days after final report delivery

# 5. DELIVERABLES

The Consultant will provide the following deliverables:

1. Executive Summary Report — Non-technical overview for leadership
2. Technical Findings Report — Detailed findings with CVSS scores, evidence, and remediation
3. Risk Assessment — Overall security posture score and rating
4. Remediation Roadmap — Prioritized action plan
5. Findings Presentation — Live debrief session
6. Retest Report — Verification of remediated findings (within 30 days)

# 6. CONFIDENTIALITY & DATA PROTECTION

## 6.1 Non-Disclosure

The Consultant agrees to:

- Maintain strict confidentiality of all Client information, systems, and findings
- Not disclose any results or vulnerabilities to any third party
- Store all engagement data in encrypted form
- Securely destroy all engagement data upon Client request or within [90] days of engagement completion
- Not use any Client data for marketing, case studies, or publications without explicit written consent

## 6.2 Data Handling

- All report data stored with AES-256 encryption at rest
- Data transmitted via encrypted channels (SSH, HTTPS, encrypted email)
- No Client data stored on public cloud services without Client approval
- Consultant will not access, copy, or store actual production data beyond what is necessary to demonstrate a finding

## 7. LIABILITY & INDEMNIFICATION

### 7.1 Limitation of Liability

The Client acknowledges that penetration testing inherently carries risk of unintended service disruption. The Consultant will exercise reasonable care and industry-standard practices to minimize risk.

The Consultant's total liability under this Agreement shall not exceed the total fees paid for the specific engagement.

### 7.2 Client Responsibility

The Client represents and warrants that:

- The Client has full legal authority to authorize testing of all in-scope systems
- The Client owns or has written authorization from owners of all in-scope systems
- The Client has notified relevant stakeholders (hosting providers, cloud vendors) as required
- The Client maintains current backups of all in-scope systems
- The Client will not hold the Consultant liable for disruptions resulting from authorized testing activities performed in good faith

### 7.3 Insurance

The Consultant maintains:

- Professional Liability (Errors & Omissions) Insurance: \$[X,000,000]
- General Liability Insurance: \$[X,000,000]
- Cyber Liability Insurance: \$[X,000,000]

## 8. COMPENSATION

As detailed in the attached Statement of Work (Exhibit A):

- Total Fee: \$[AMOUNT]
- Payment Schedule: 50% upon SOW execution, 50% upon final report delivery
- Payment Terms: Net 30
- Late Payment: 1.5% per month on overdue balances

## 9. TERM & TERMINATION

### 9.1 Term

This Agreement is effective from the Effective Date through completion of all deliverables and the retest window.

### 9.2 Termination

Either party may terminate this Agreement:

- For Convenience: With 5 business days written notice. Client will pay for all work completed to date.
- For Cause: Immediately upon written notice if the other party materially breaches this Agreement and fails to cure within 10 business days.
- Emergency Stop: Either party may immediately halt all testing activities by contacting the emergency contacts listed in Section 3.

## 10. GENERAL PROVISIONS

### 10.1 Independent Contractor

The Consultant is an independent contractor, not an employee of the Client.

### 10.2 Governing Law

This Agreement shall be governed by the laws of the State of [STATE].

### 10.3 Entire Agreement

This Agreement, together with the attached Statement of Work (Exhibit A), constitutes the entire agreement between the parties.

### 10.4 Amendments

This Agreement may only be modified by written amendment signed by both parties.

---

## SIGNATURES

CONSULTANT: [YOUR COMPANY NAME]

Signature: \_\_\_\_\_

Name: \_\_\_\_\_

Title: \_\_\_\_\_

Date: \_\_\_\_\_

CLIENT: [CLIENT COMPANY NAME]

Signature: \_\_\_\_\_

Name: \_\_\_\_\_

Title: \_\_\_\_\_

Date: \_\_\_\_\_

---

Exhibit A: Statement of Work (attached separately)